



Gmail Verification Engineering Requirements

CASA, engineering controls, and Google submission requirements

Gmail Verification Engineering Requirements

Purpose

This document sets out the engineering, security, and submission requirements for Hussh's public Gmail integration before Google OAuth verification is submitted or resumed.

1. CASA security assessment is required

Hussh uses `gmail.readonly`, which Google classifies as a **restricted** Gmail scope. Hussh also processes and stores Gmail-derived receipt information on server-side systems. Under Google's current policy, this combination requires a Cloud Application Security Assessment (CASA).

This is a required workstream, not an optional security improvement. The exact assessment level, assessment timing, and whether Google issues a Letter of Validation are determined by Google and the authorized assessor during the verification process.

CASA evidence that must be prepared

- a complete Gmail information-flow diagram, from Google authorization through storage, processing, deletion, and any AI provider;
 - an inventory of systems, databases, service accounts, employees, vendors, and subprocessors that can access Gmail-derived information;
 - proof of encryption in transit and at rest, secure key management, and secure OAuth token handling;
 - access-control evidence showing that only authorized services and personnel can access Gmail-derived information;
 - vulnerability management, patching, secure-development, incident-response, and security-monitoring evidence;
 - retention and deletion evidence, including test results; and
 - an assigned security owner for the assessment and any ongoing annual or periodic obligations.
-

2. Engineering work required

2.1 Permission design and OAuth flow

The Gmail connection journey must request only the permission needed for the feature a person is enabling.

- Receipt and inbox features must use the read-only connection.
- Sending permission must be requested through a separate, feature-specific authorization journey only when a person chooses to enable owner-approved sending. The current send journey includes both read and send permission, so engineering must either justify that read access or narrow the request.
- Web, iOS, and Android must request the same purpose-appropriate scope set.
- Existing accounts with older broad grants must have a safe reconnect or revoke path so their active permissions can be corrected.
- The Google Cloud consent screen, runtime request, reviewer video, and scope justification must show the same scope list.

2.2 Clear consent disclosure before Google authorization

Immediately before a person is sent to Google's authorization screen, the app must show a dedicated disclosure with an affirmative continue action.

The disclosure must state:

- which Gmail information Hussh will access;
- the user-facing features that use it;
- what information is stored and for how long;
- whether Gmail information can be processed by AI services;
- how the person disconnects and deletes Gmail information; and
- a direct link to the relevant privacy-policy section.

This must work consistently across web, iOS, and Android and must be covered by automated UI tests.

2.3 Storage, retention, and deletion controls

Gmail-derived information must have a documented, enforced lifecycle.

- Define the minimum retained fields for each Gmail feature.
- Define an approved retention period for each stored information type.
- Run an automatic, monitored cleanup process when the retention period ends.
- Provide a visible Gmail-information deletion control.
- Ensure disconnect revokes Google access and removes provider-derived Gmail records according to the declared deletion boundary.
- Document any information deliberately preserved outside that boundary, such as a person-approved private memory record, and provide its own deletion path.
- Test deletion against production-like databases, background jobs, caches, and recovery procedures; retain evidence of the test.
- Correct stale user-facing labels that describe disconnect as retaining stored receipts when the deployed deletion behavior removes them.

2.4 AI processing and information-safety controls

Every Gmail-to-AI processing path must be documented, consented, and protected.

- Inventory receipt analysis, inbox chat, KYC, and any future Gmail-to-model feature before release.
- Limit each flow to the minimum Gmail information required for that feature.
- Ensure the provider configuration complies with Google's Limited Use rules, including no use of Gmail-derived information to train a general AI model.
- Implement and test prompt-injection protections for Gmail content.
- Prevent Gmail content from appearing in application logs, analytics, error reports, test fixtures, or unauthorized support tooling.
- Make the privacy policy and pre-authorization disclosure match the deployed AI processing behavior.

2.5 Security controls and verification

Engineering must provide repeatable proof that the Gmail integration is secure.

- Encrypt Gmail-derived information and OAuth tokens at rest; use secure transport for every connection.
- Keep encryption keys separate from stored ciphertext and restrict key access.
- Apply service-to-service authentication, least-privilege database access, and audited administrative access.
- Add tests for scope separation, consent disclosure, data deletion, retention cleanup, access denial, and AI-information boundaries.
- Maintain security logs that record access and deletion events without exposing Gmail content.
- Keep an incident-response procedure specifically covering unauthorized access to Google user information.

3. Public policy and user-help requirements

The live privacy policy must include a Gmail-specific section that accurately explains access, collection, use, storage, sharing, AI processing, retention, and deletion. It must include Hussh's Limited Use commitment.

User-help content must explain how to disconnect Gmail, delete Gmail information, and delete any separately saved information where applicable. The policy, product copy, and actual system behavior must remain aligned through release testing.

4. Google submission and reviewer requirements

Before submission, a designated owner must confirm the following outside the repository:

1. The Google Cloud OAuth consent screen is configured for the correct external application, verified domains, redirects, contacts, homepage, terms, and privacy-policy links.
 2. The submitted scopes exactly match the deployed web, iOS, and Android flows.
 3. Each requested scope has a feature-specific justification and is demonstrated in the product.
 4. An English reviewer video shows the full journey: account sign-in, required vault setup, Gmail connection, in-product disclosure, each submitted feature, disconnect, and deletion.
 5. A reviewer test account and written steps allow Google to complete the journey without Hussh team assistance.
 6. The CASA assessment engagement and evidence package are ready for the applicable Google review stage.
-

5. Approval gate

The Gmail integration is ready for Google verification only when the CASA work is active and complete for the required assessment level, engineering controls are deployed and tested, user disclosures and policy are published, and the Google Cloud submission accurately represents the released product.

Official policy sources

- [Gmail API scopes](#)
- [Google Workspace user data policy](#)
- [Google security assessment guidance](#)